

CSIT302 Cybersecurity

Day 5-1 – Network Segmentation

Subject Coordinators: Dr Partha Sarathi Roy
School of Computing and Information Technology

Segmenting the Network

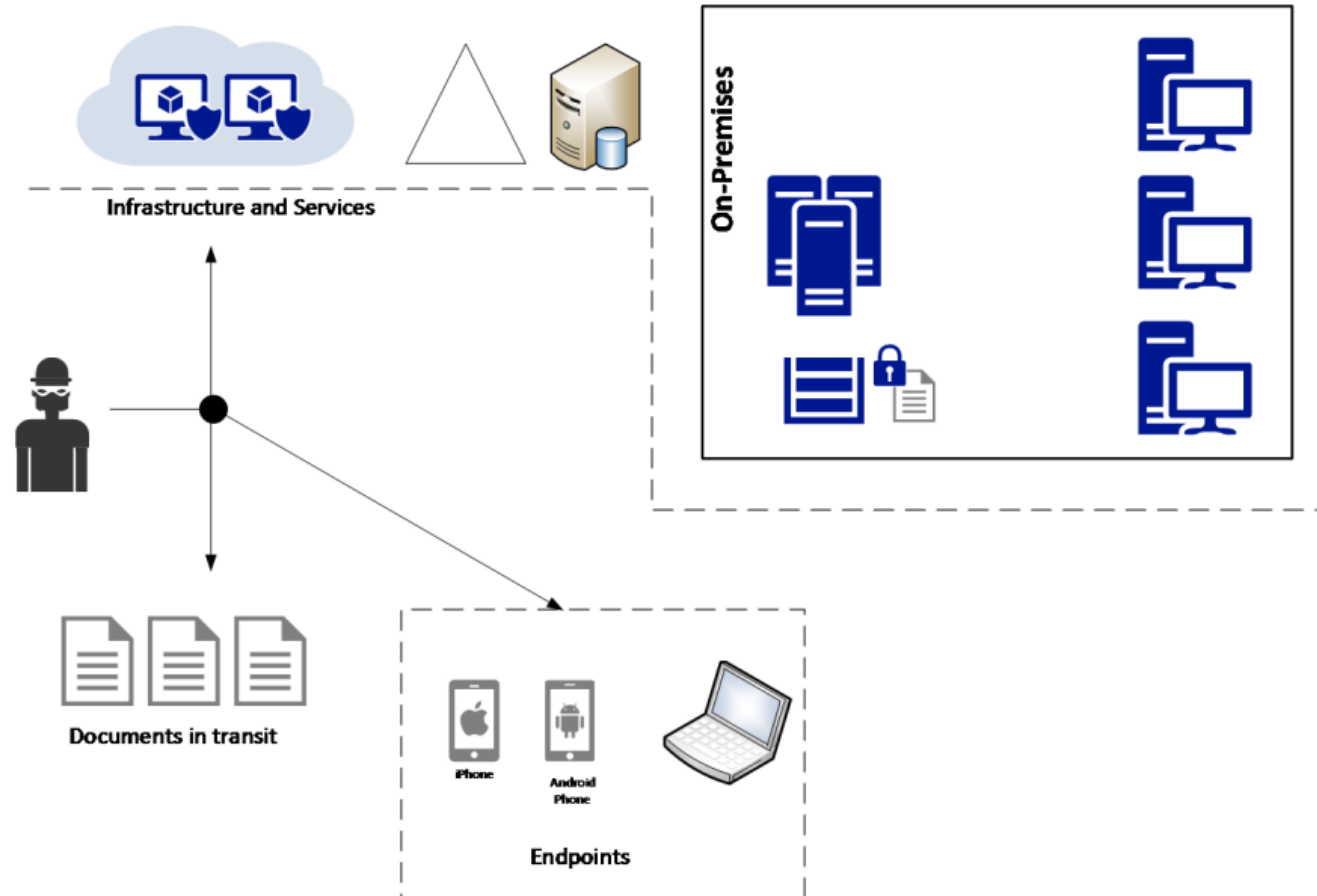
- Network segmentation
 - Network segmentation in computer networking is ***the act or practice of splitting a computer network into subnetworks***, each being a network segment.
 - The network must be segmented, isolated, and mechanisms to mitigate intrusion to be provided.
 - Types: Physical, logical and virtual segmentations
- Reasons for having network segmentation
 - **Performance**
 - ✓ Ex) High bandwidth applications
 - **Security**
 - ✓ Ex) Users should not talk directly to database servers.

Defence in Depth Approach

- *Defence in depth approach* is to ensure:
 - There are **multiple layers of protection**.
 - Each layer will have its own set of security controls, which will end up delaying the attack.
 - The sensors available in each layer will alert users whether or not something is happening.
- Purpose
 - To break the attack kill chain before the mission is fully executed.

Defence in Depth Approach

- Implementation of defence in depth approach consists of three sections:
 - Infrastructure and Services
 - Documents in transit
 - Endpoints



Defence in Depth Approach

- **Infrastructure and services**

- Attacker can target the organization's infrastructure and services.
- All services that are offered by the organization is needed to be enumerated to identify the possible attack vectors:
 - ✓ Identify which *assets* that the organization has.
 - ✓ Then, specify that the *potential attackers and the possible attack techniques*.
- Add security controls to mitigate the vulnerabilities.
 - ✓ Examples of security controls: Patch management, server protection via security policies, network isolation, backups and etc.

Defence in Depth Approach

- **Infrastructure and services**

- Two forms of infrastructure:

- ✓ On-premises

- ✓ IaaS (Infrastructure as a Service) of cloud computing

- Services can be provided based on the form of infrastructure.

- Threat modelling and implementation of security control must be considered in the hybrid environment (on-premises + IaaS) if the organisation is leveraging their services using IaaS.

- The goal of infrastructure security

- ✓ To reduce the vulnerability count and severity, reduce the time of exposure, and increase the difficulty and cost of exploitation.

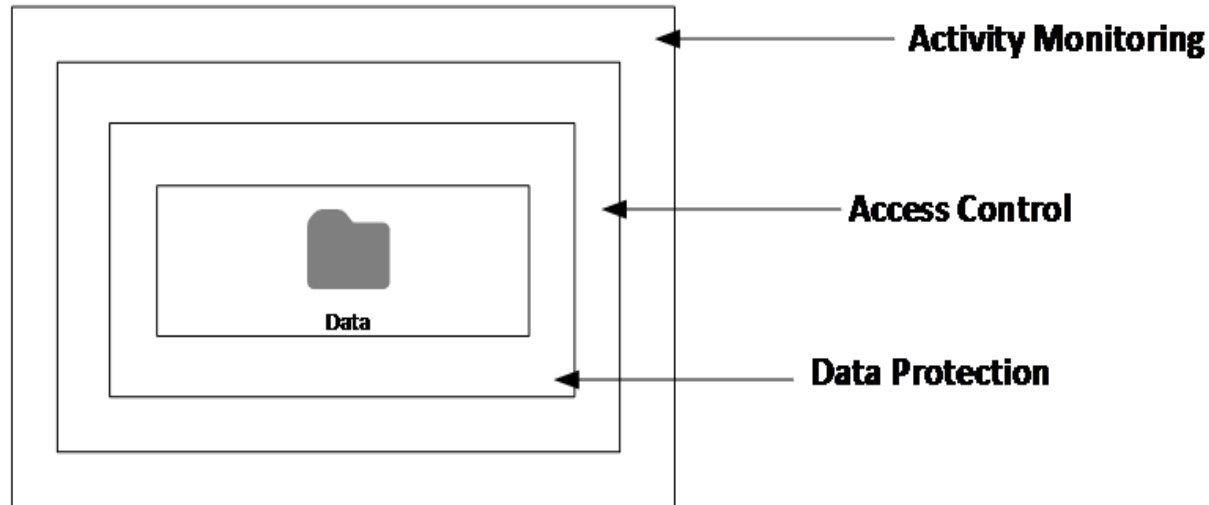
Defence in Depth Approach

- **Documents in transit**

- *Documents* could be any type of data.
- This data is usually vulnerable when it is in transit (from one location to another).
- *Data in transit must be protected by **encryption**.*
- The encryption in transit should be done in both public and internal networks.

Defence in Depth Approach

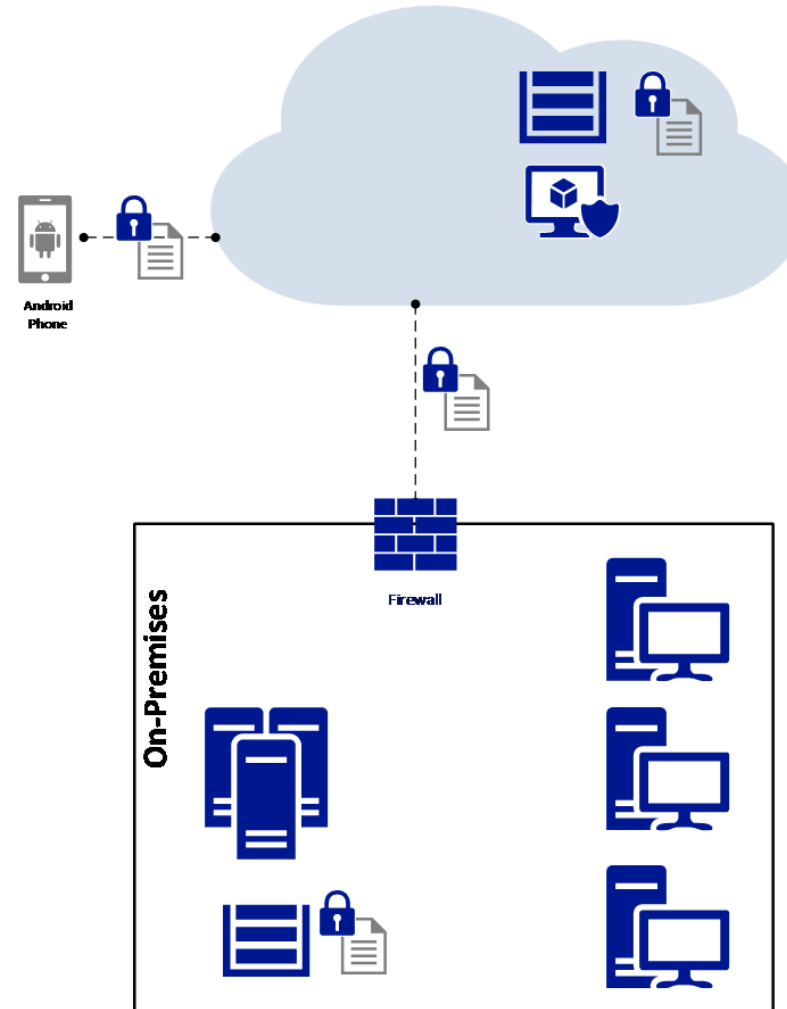
- Besides encryption, other security controls for monitoring and access control must be included as shown in the following diagram.



- Note that adding different layers of protection and detection is the entire essence of the *defence in depth approach*.

Defence in Depth Approach

- In this diagram, a document was originally encrypted at rest in a server located on-premises; it travelled via the internet, the user was authenticated in the cloud, and the encryption was preserved all the way to the mobile device that also encrypted it at rest in the local storage:



We should consider the entire **end-to-end** communication path in order to identify potential threats and ways to mitigate them.

Defence in Depth Approach

- **Endpoints**

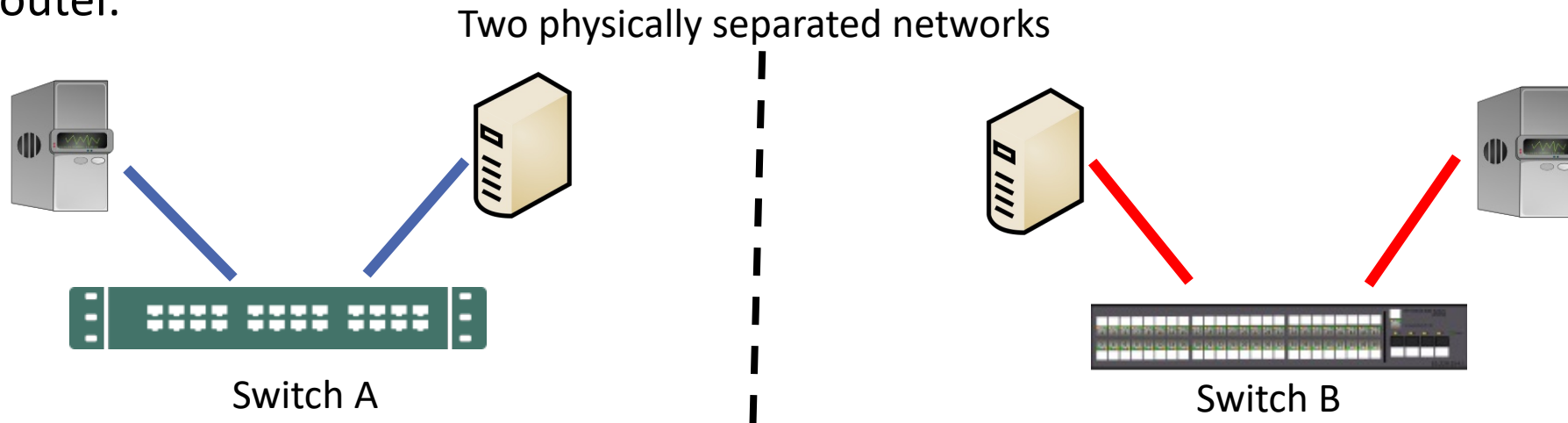
- Nowadays, an endpoint is basically any device that can consume data (beyond computers).
- In general, we need to assume that the endpoint can be a mobile or an IoT device.
- We must perform threat modelling to uncover all attack vectors and plan mitigation efforts accordingly.
- Some of the countermeasures for endpoints include
 - ✓ Separation of corporate and personal data/apps (isolation)
 - ✓ Use of TPM (Trusted Platform Module) hardware protection
 - ✓ OS hardening
 - ✓ Storage encryption

Physical Network Segmentation

- The network will grow according to the demand, and its security features are rarely revisited as the network expands.
- Obtaining an accurate view of what is currently implemented in the network is a challenging task to the blue team.
- The first step to establishing an appropriate physical network segmentation is *to understand the logical distribution of resources according to the company's needs*.
 - For example, depending on the size of the organisation, the blue team can select physical network segmentation or Virtual Local Area Network (VLAN).

Physical Network Segmentation

- Establishing a physical network segmentation
 - No data flows between the segmented networks unless there is another switch or router.



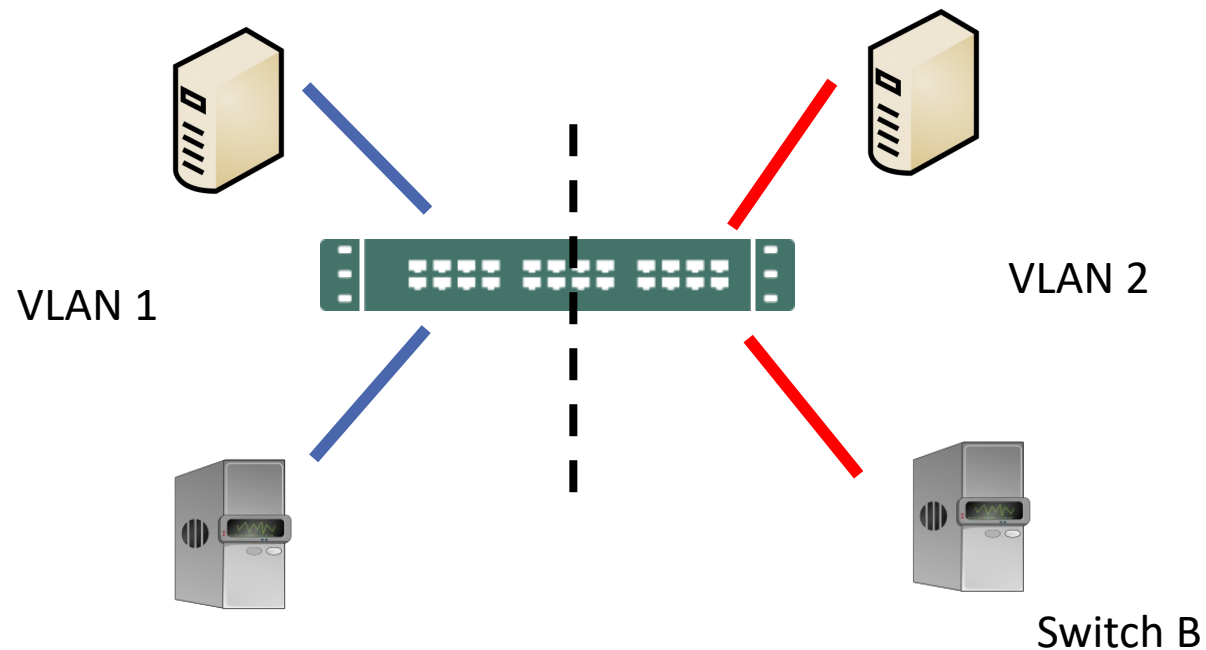
- Physical network segmentation will provide good isolation, but there are issues:
 - ✓ Efficiency: There are only two hosts in each network, but a switch has, for example, 24 ports.
 - ✓ Scalability: What if there are too many hosts for one switch to handle?

Virtual Local Area Network

- VLANs

- *Separated logically not physically.*

- VLAN 1 cannot communicate with VLAN 2 without a router.



Virtual Local Area Network

- **Virtual Local Area Network (VLAN)** (for small-and medium-sized organizations based on department)
 - In small-and medium-sized organizations, it might be easier to aggregate resources according to their departments—for example, resources that belong to the financial department, human resources, operations, and so on.
 - This will isolate the resources per department.
 - *Limitation:* The problem with this design is that complication will be caused *when different departments want to access the common resource like a file server*. In this case **cross VLAN access will be needed** but this requires multiple rules, different access conditions and more maintenance. For this reason, large networks usually avoid this approach.

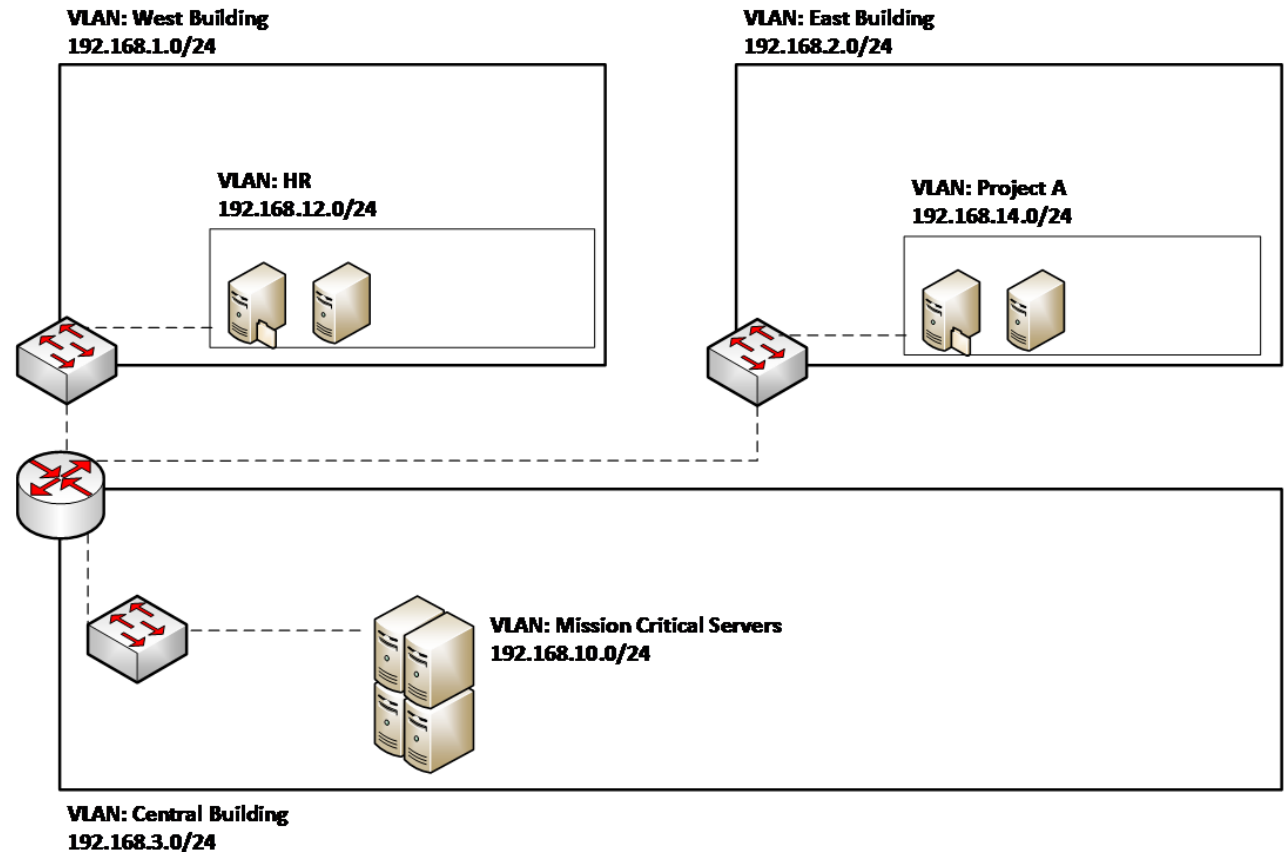
Virtual Local Area Network

- VLAN based on other aspects
 - Business objectives: Using this approach, one can create VLANs that have resources based on common business objectives.
 - Level of sensitivity: Assuming that an up-to-date risk assessment of the resources has been performed, one can create VLANs based on the *risk level* (high, low, medium).
 - Location: For large organizations, sometimes it is better to organize the resources based on location.
 - Security zones: Usually, this type of segmentation is combined with others for specific purposes, for example, one security zone for all servers that are accessed by partners.

Physical Network Segmentation

- Mixed VLAN

There is no one perfect solution for network segmentation based on VLANs. The mixed VLAN is usually used as the diagram shows.



Physical Network Segmentation

- Best practices for security of network segmentation:
 - Use SSH to manage your switches and routers.
 - Restrict access to the management interface.
 - **Disable ports that are not used.**
 - Leverage security capabilities to prevent *MAC flooding attacks*.
 - Leverage port-level security to prevent attacks, such as *DHCP snooping*.
 - Make sure that you update the switch's and router's firmware and operating systems.

Discovering network

- The internal reconnaissance techniques can be used to discover the network structure in the organization.
 - Programs such as *Nmap* or basic commands such as *traceroute* is still useful to discover and identify the network structure.
 - Commercial tools such as Network Sonar Wizard can be used to provide more graphical outs to users including a network structure diagram and geographic location of network hosts and devices.

Securing Remote Access to the Network

- Remote access needs

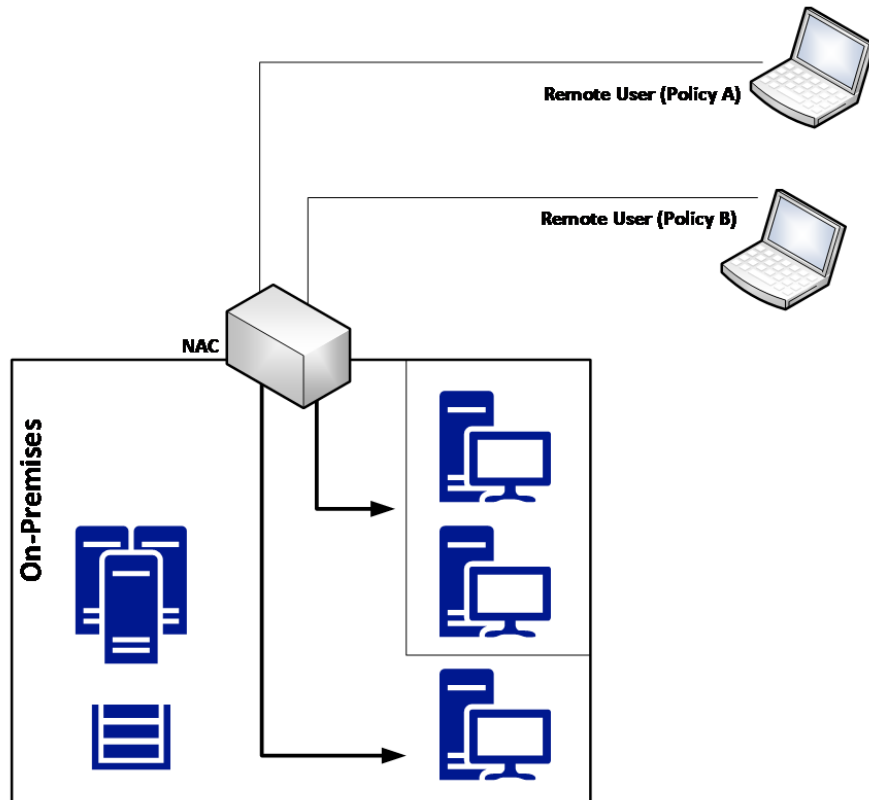
- Remote access to a corporate network is required when
 - ✓ a company has employees that work from home;
 - ✓ an employee will be traveling and will need remote access to the company's resources.
- We need to consider not only segmentation plan, but also a **network access control (NAC)** system that can evaluate the remote system prior to allowing access to the company's network.
- Definition of NAC: NAC is an approach to computer security that attempts to unify endpoint security technology (such as antivirus, host intrusion prevention, and vulnerability assessment), user or system authentication and network security enforcement.

Securing Remote Access to the Network

- Evaluation criteria for remote system
 - Whether the remote system has the latest patches
 - Whether the remote system has antivirus enabled
 - Whether the remote system has a personal firewall enabled
 - Whether the remote system is compliant with mandate security policies
- NAC example: Cisco NAC
<https://www.cisco.com/c/en/us/products/security/what-is-network-access-control-nac.html>

Securing Remote Access to the Network

- The following diagram shows an example of a network access control (NAC) system:

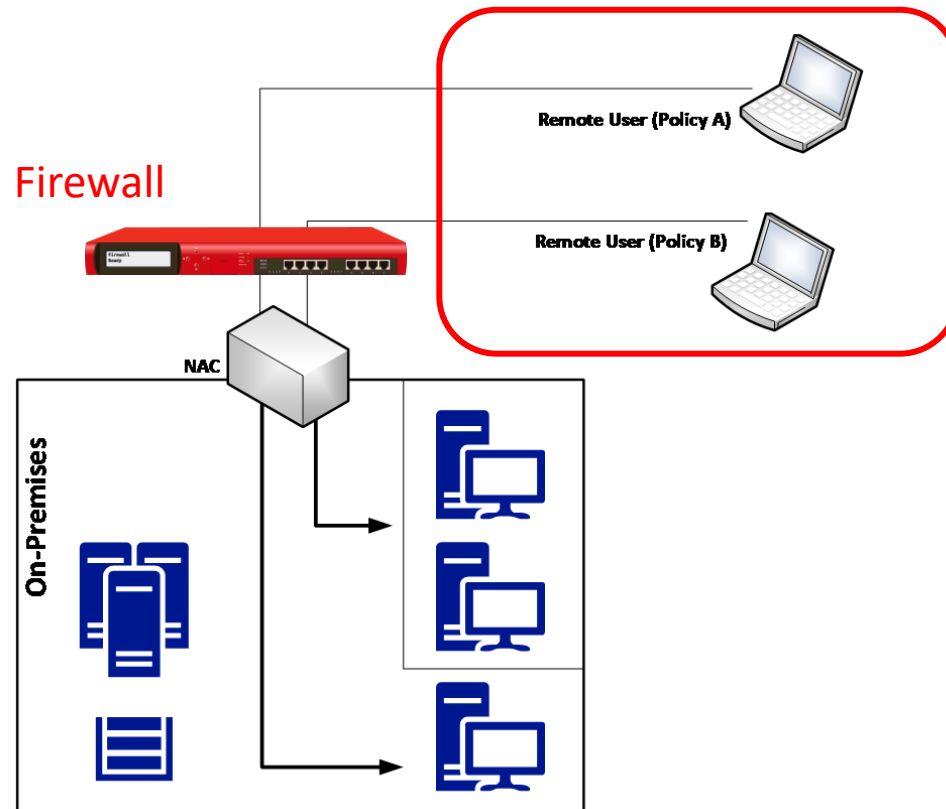


In this scenario, the NAC is responsible for

- validating the current health state of the remote device;
- performing software-level segmentation by allowing the source device to only communicate with predefined resources located on premises.

Securing Remote Access to the Network

- The following diagram shows another example of a network access control (NAC) system: **VLAN**



In this scenario, a company **isolates all remote access users in one specific VLAN** and **have a firewall** in between this segment and the corporate network to control the traffic coming from remote users. This is usually used when the company wants to restrict the type of access users will have when they are accessing the system remotely.

Securing Remote Access to the Network

- It is also *important to have an isolated network to quarantine computers that do not meet the minimum requirements* to access network resources.
 - This quarantine network should have remediation services that will scan the computer and apply the appropriate remediation to enable the computer to gain access to the corporate network.
 - Related article: <https://www.forbes.com/2010/11/10/microsoft-viruses-security-technology-quarantine.html#5fe6fc293c9e>

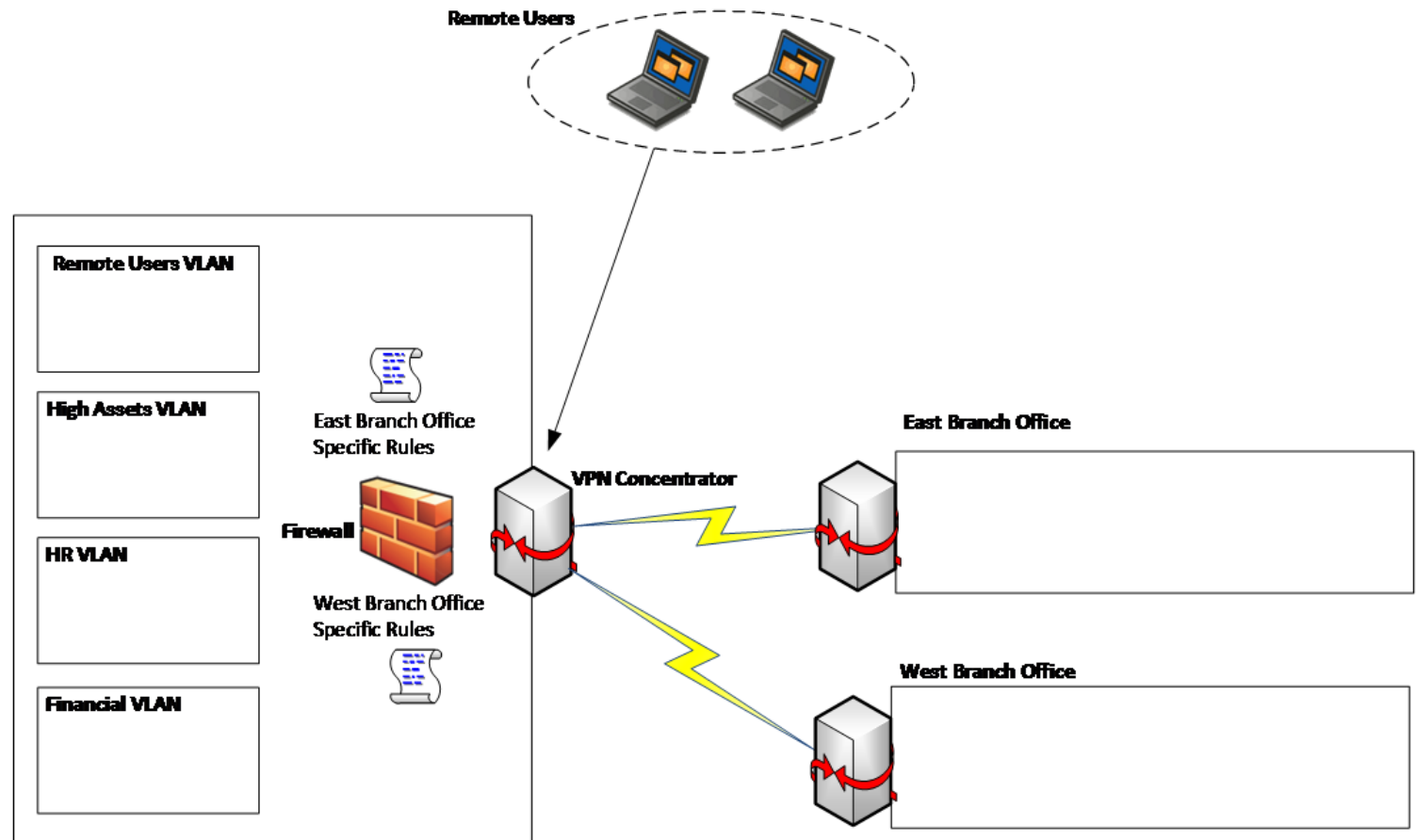
Securing Remote Access to the Network

- Site-to-Site VPN (Virtual Private Network)
 - VPN enables to establish *a secure (encrypted) traffic channel between two remote sites.*
 - VPN usually use IPSec protocol, but some software VPN also uses TLS (Transport Layer Security) protocol.
 - ✓ IPSec is a secure network protocol suite that authenticates and encrypts the packets of data to provide secure encrypted communication between two computers over an Internet Protocol network.
 - VPN provide many options, the encrypting the traffic is default, but not mandatory. In transport mode, the data in the traffics are not encrypted.

Securing Remote Access to the Network

- Site-to-Site VPN

- One common scenario for organizations that have remote locations is to have a secure private channel of communication between the main corporation network and the remote network, which is done via **site-to-site VPN**.

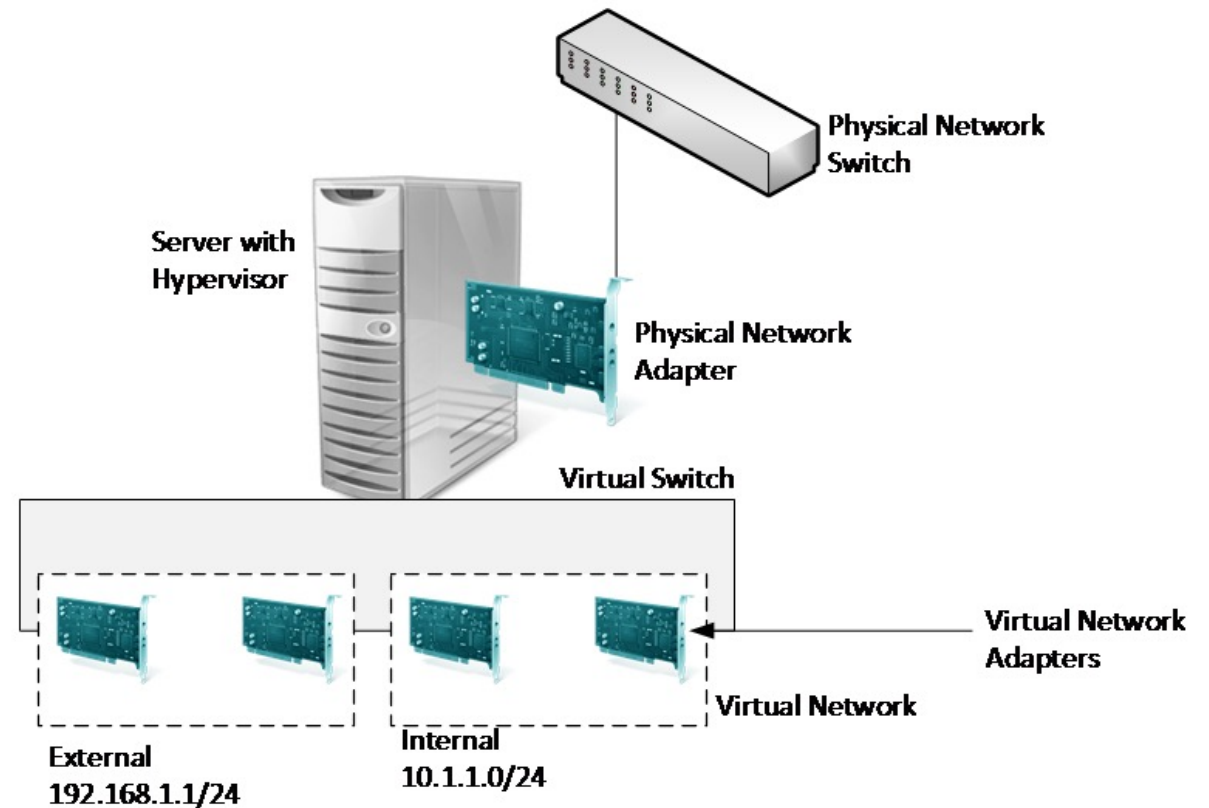


Securing Remote Access to the Network

- Example: The network design shown in the previous diagram
 - Each branch office has a set of rules in the firewall, which means that when the site-to-site VPN connection is established, the remote branch office will not have access to the entire headquarters' main network, but just some segments.
 - When planning your site-to-site VPN, the "need to know" principle should be enforced to only allow access to what is really necessary. (If the East Branch Office has no need to access the HR VLAN, then access to this VLAN should be blocked.)

Virtual Network Segmentation

- Security must be embedded even in virtual networks of virtual machines (VMs) created/managed by a hypervisor (like VirtualBox or VMWare) in a server (host machine) as shown in the diagram.



Virtual Network Segmentation

- Planning virtual network segmentation
 - Although there are various virtualization platform available, it would be better to take a vendor-agnostic approach since the core principles of virtual network segmentation are the same regardless of the platform.
 - Note that there is isolation within the virtual switch; in other words, **the traffic from one virtual network is not seen by the other virtual network**. Each virtual network can have its own subnet, and all virtual machines within the virtual network will be able to communicate among themselves, but it won't traverse to the other virtual network.

Virtual Network Segmentation

- For communications between two or more virtual networks, a router that has multiple virtual network adapters is needed. (It could be a VM with a routing service enabled.)
- It is possible to implement, at the virtual switch level, some security inspections using virtual extensions.
- The advantage of using these types of extensions is that you are inspecting the packet before transferring it to other networks, which can be very beneficial for your overall network security strategy.

Virtual Network Segmentation

- Network security of virtual network
 - *The traffic that originated in one VM can often traverse to the physical network and reach another host connected to the corporate network.*
 - Hence, the following capabilities are enabled in the virtual switch:
 - ✓ **MAC address spoofing (arp spoofing) prevention:** This prevents malicious traffic from being sent from a spoofed MAC address.
 - ✓ **DHCP guard:** This prevents virtual machines from acting or responding as a DHCP server.
 - ✓ **Router guard:** This prevents virtual machines from issuing router advertisement and redirection messages.
 - ✓ **Port ACL (access control list):** This allows you to configure specific access control lists based on MAC or IP addresses.

Case Study: Amazon AWS

- AWS provides several security capabilities and services to increase privacy and control network access. These include:
 - **Network firewalls** built into Amazon Virtual Private Cloud (VPC), and **web application firewall** (WAF) capabilities in AWS WAF let you create private networks, and control access to your instances and applications
 - Customer-controlled encryption in transit with **TLS across all services**.
 - Connectivity options that enable **private, or dedicated, connections** from your office or on-premises environment.
 - **Automatic encryption** of all traffic on the AWS global and regional networks between **AWS secured facilities**.
- Source: <https://aws.amazon.com/security/>